

1. Project Planning & Management

- **Project Proposal – Overview of the project, objectives, and scope.**

Project 1: Building and Operating a Mini Security Operations Center (SOC)

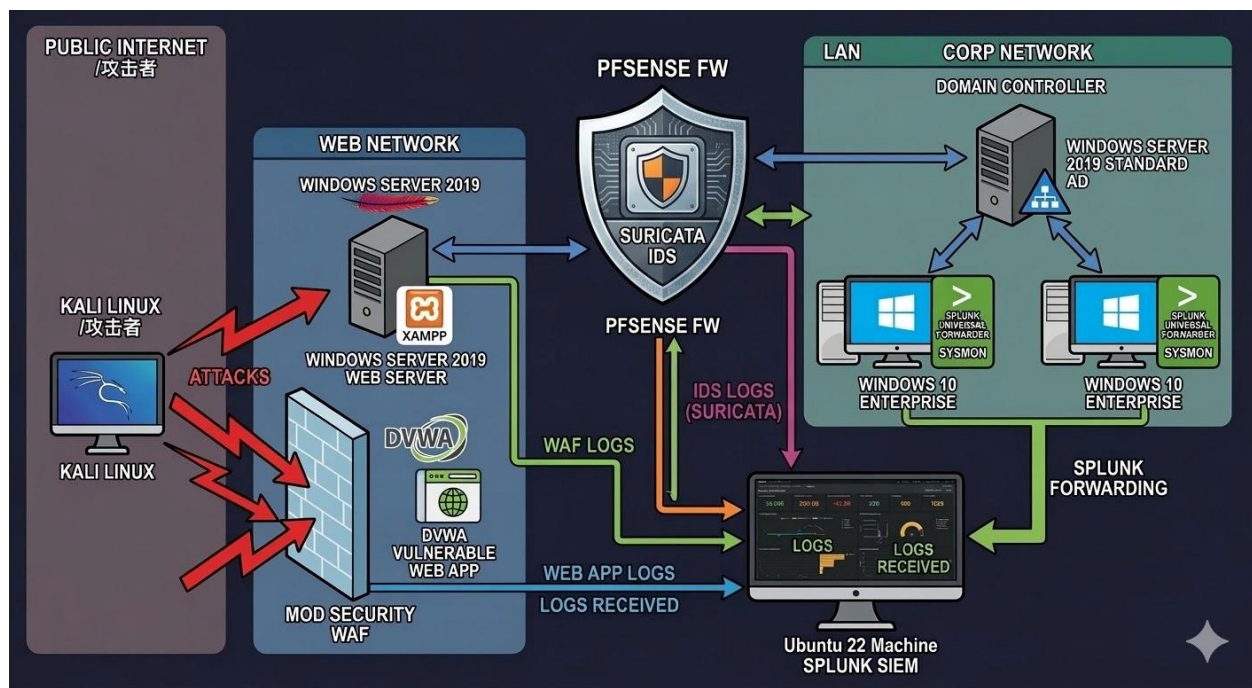
- **Project Title:** Security Operations Center (SOC) Implementation and Threat Detection.

Objectives:

- 1 - Simulate a full SOC workflow including log ingestion, threat detection, triaging, and reporting.
- 2 - To build a functional SOC environment using Splunk for monitoring, a pfSense firewall for network security, and various detection tools like Suricata and ModSecurity.

- **Project Plan – Timeline (Gantt chart), milestones, deliverables, and resource allocation.**

Project Plan:



Timeline (Gantt Chart View):

This timeline follows the 4-week sprint structure suggested in project booklet for building the SOC and performing incident response.

Week 1: SOC Setup & Log Ingestion:

Environment Setup (March)

Tasks:

- Set up a centralized logging server using Splunk.
 - Install Splunk Enterprise on Ubuntu.
- Configure log sources: Windows, firewall, and IDS.
 - Deploy pfSense Firewall and configure LAN/WAN interfaces.
 - Set up Windows Domain Controller.

Deliverables:

- Operational log ingestion pipeline.
- Documented SOC architecture.

Week 2: SIEM Configuration & Use Case Development:

Data Ingestion & Security Layers (April)

- Install Universal Forwarders and Sysmon on endpoints.
- Integrate Suricata (IDS/IPS) and ModSecurity (WAF).
- Verify log flow from all sources into Splunk.

Tasks:

- Deploy SIEM platform Splunk.
- Configure 3–5 real-world use cases (e.g., brute force, malware infection).

Deliverables:

- Use case documentation with correlation rules.
- Screenshots of triggered alerts.

Week 3: Alert Triage and Incident Management:

Detection & Simulation (Early May)

- Configure SPL rules and alerts in Splunk.
- Simulate attacks (SQLi for WAF, testmyids.com for Suricata).
- Perform Active Directory attack simulations.

Tasks:

- Triage and analyze triggered alerts.
- Apply MITRE ATT&CK mapping to events.

Deliverables:

- Triage sheets and IOC identification.
- Evidence of containment or analysis recommendations.

Week 4: Reporting & Final Presentation:

Documentation & Hardening (Mid May)

- Draft the Incident Response Playbook.
- Finalize the Technical Report and Executive Summary.
- Record the project demonstration video.

Tasks:

- Prepare KPI metrics.
- Perform root cause analysis for a selected incident.

Deliverables:

- Final Report: SOC architecture, SIEM rules, KPIs, analysis.
- Presentation: SOC design, use cases, response strategy.

Project Milestones & Deliverables:

This table outlines the major phases of SOC project.

Milestone	Deliverable	Due Date
M1: Planning & Scope	Project Proposal & Risk Assessment	Jan 27, 2026
M2: Research & Req.	Literature Review & Hardware/Software Specs	Mar 1, 2026
M3: System Design	Network Topology & SIEM Architecture Design	Apr 3, 2026
M4: Implementation	Functional SOC (Splunk, pfSense, WAF, IDS)	May 17, 2026
M5: Final Submission	Final Report, Test Cases, & Presentation	May 24, 2026

Deliverables:

1. A fully configured Splunk Enterprise instance.
2. Active Directory and Windows log forwarding.
3. Web Application Firewall (WAF) integration.
4. Intrusion Detection/Prevention System (IDS/IPS) setup.

Resource Allocation:

distribution of responsibilities:

Role	Responsibility	Primary Tools
SOC Architect	Infrastructure setup, pfSense configuration, and networking.	VMware, pfSense
SIEM Administrator	Splunk installation, Index management, and Syslog-ng setup.	Splunk, Linux (Ubuntu)
Security Engineer	IDS/IPS (Suricata) and WAF (ModSecurity) implementation.	Suricata, Apache/XAMPP
Endpoint Specialist	Sysmon deployment, GPO configuration, and Windows logging.	Windows Server, Sysmon
Threat Hunter	Writing SPL queries, creating alerts, and attack simulation.	Splunk (SPL), Kali Linux
Technical Writer	Documentation, Gantt chart, and Final Presentation.	GitHub, LaTeX/Office

Task Assignment & Roles – Defined responsibilities for team members.

Task	Assignment	responsibilities
AD environment and, Sysmon deployment, GPO configuration, Windows logging	Abdalaziz Mohammad Mohammad	<u>All responsible for his:</u> 1- Infrastructure setup, configuration, and networking. 2- Index management, and Syslog-ng setup. 3- Writing SPL queries, creating alerts, and attack simulation. 4 - collect his logs and send it to Splunk. 5 - create use cases and correlate it. 6 - make Documentation, Gantt chart, and Final Presentation (for his specific task according to the previous schedule).
Splunk installation	Ahmed Hamdy	
PFSENSE FW	Marko Maged	
SURICATA IDS/IPS	Ahmed Atef	
XAMP WEB SERVER AND DVWA WEB APPLICATION	Bassam Alsayed	
WAF (ModSecurity)	Ahmed Tarek	

Tasks Sequence:

- 1- install splunk.
- 2- install forwarder.
- 3- configure Domain Controller Environment.
- 4- install Xampp Web app server.
- 5- install Pfsense firewall.
- 6- install Suricata IPS/IDS.
- 6- configure DVWA vulnerable Web app on xampp.
- 7- configure securityMod WAF To detect web app attacks.
- 8- write rule in splunk to generate alert.
- 9- detect Active Directory Attacks.

SOC Team4: Lab Configuration Standard

1. Core Infrastructure & Host Specifications

Category	Component	Details
Physical Host	Laptop (Win 11 Pro)	i5-1235U (10 Cores), 16GB RAM, 512GB SSD
Virtualization	Platforms Used	VMware Workstation
SIEM Platform	Ubuntu 22.04 LTS	Splunk Enterprise (IP: 192.168.254.156)
Security Gateway	pfSense 2.7.x	Suricata IDS enabled on WAN/DMZ

2. Virtual Machine Inventory (Endpoints & Servers)

Hostname	Operating System	IP Address	Primary Role	Domain Status
TEAM4-DC	Win Server 2019	192.168.254.140	Domain Controller (DNS/AD)	SOC.DEPI
WEBSRV	Win Server 2019	192.168.120.100	XAMPP, DVWA, SQL Server	SOC.DEPI
TEAM4-PC1	Win 10 Enterprise	10.1.1.100	HR Workstation	SOC.DEPI
TEAM4-PC2	Win 10 Enterprise	10.2.1.100	Finance Workstation	SOC.DEPI

Hostname	Operating System	IP Address	Primary Role	Domain Status
KALI	Kali 2025.4	192.168.250.128	VAPT / Attacker Machine	Non-Domain

3. Network Topology & Segmentation (pfSense)

Interface	Subnet Range	Gateway	VLAN / Purpose	VMnet
WAN	192.168.250.0/24	192.168.250.129	Internet / External Exposure	VMnet0
LAN	192.168.254.0/24	192.168.254.2	DataCenter / Management	VMnet1
DMZ	192.168.120.0/24	192.168.120.1	Web Hosting (WEBSRV)	VMnet2
OPT1	10.1.1.0/24	10.1.1.1	Corporate (HR Dept)	VMnet3
OPT2	10.2.1.0/24	10.2.1.1	Corporate (Finance Dept)	VMnet4

4. Identity & Access Management (AD Credentials)

User / Service	Username	Password	Notes
Domain Admin	administrator	P@\$w0rd!	High Privilege
HR User	AAli	Password1	TEAM4-PC1 Login
Finance User	AHamdy	Password2	TEAM4-PC2 Login
Special User	MMaged	Password2026!@#	Target for privilege escalation
Service Acc	SQLService	MYpassword123#	Targeted for Kerberoasting

Detection & Monitoring Stack

- **WAF (ModSecurity):** Configured on WEBSRV to log to C:\xampp\apache\logs\modsec_audit.log.
- **Logging:** Splunk Universal Forwarder installed on all Windows endpoints.

- **SIEM Integration:** Logs are centralized on the Ubuntu Splunk instance for correlation.

1. Use Case: Brute Force Attack

1.1. Description

A brute force attack occurs when an adversary attempts to gain access to a system by guessing credentials through multiple login attempts. This can target various services such as SSH, RDP, or web application logins. Detecting these attacks involves identifying a high number of failed authentication attempts from a single source IP within a short time window.

1.2. Why It Matters

Successful brute force attacks lead to account compromise, data breaches, and ransomware deployment. Early detection allows the SOC to block the offending IP and reset compromised credentials before the attacker gains a foothold.

1.3. Data Sources

- **Authentication Logs:**
 - Windows Event Log (EventCode 4625)
 - Event ID 4625 – An account failed to log on
 - Linux /var/log/secure, application logs.
- **Web Logs:**
 - HTTP 401 status codes.

1.4. SPL Rule Example

```
index="windows_dc" EventCode=4625
|stats count min(_time) as firstTime max(_time) as lastTime
by Source_Network_Address, Account_Name
|where count >= 5
| eval severity="high"
```

2. Use Case: SQL Injection (SQLi)

2.1. Description

SQL Injection is a web vulnerability where an attacker inserts malicious SQL code into input fields or URLs to manipulate backend databases. This can result in data exfiltration, authentication bypass, or remote code execution.

2.2. Why It Matters

SQLi remains one of the most critical web application risks (OWASP Top 10). A successful attack can lead to the theft of sensitive data (PII, financial data) and full database compromise.

2.3. Data Sources

- **Web/Proxy Logs:** Web server access logs (Apache, IIS, Nginx), proxy logs (e.g., Bluecoat, Zscaler).
- **WAF Logs:** Web Application Firewall logs (e.g., AWS WAF, Cloudflare).

2.4. Splunk Rules

index=* "UNION" | stats values(sourcetype) as "Source Types", count by host

or

index=* "UNION" | stats count by sourcetype, host

3. Use Case: Network Scanning

3.1. Description

Network scanning is a reconnaissance technique used by attackers to map live hosts, open ports, and running services. This is typically the first step in the "Reconnaissance" phase of the Cyber Kill Chain.

3.2. Why It Matters

While scanning itself is not inherently malicious, it is a high-fidelity precursor to an attack. Detecting scanning activity allows defenders to identify potential threats early and harden systems before an exploit is attempted.

3.3. Data Sources

- **Firewall Logs:** Traffic logs (allow/deny).
- **IDS/IPS Logs:** Suricata, Snort.
- **Netflow Data.**

3.4. Splunk Rules

```
index="suricata" "192.168.250.128"
```

```
|rex "src_ip\"":\"(?<src>[^\"]+)"
```

```
|rex "dest_port\"":\"(?<port>\d+)"
```

```
|stats dc(port) as unique_ports_hit by src
```

```
| where unique_ports_hit > 10
```

1. Project Planning & Management (Continued)

Risk Assessment & Mitigation Plan

Potential Risk	Impact	Mitigation Strategy
Resource Exhaustion	High	The host laptop has 16GB RAM. We will limit Windows 10 VMs (HR/Finance) to 2GB RAM each to ensure Splunk and pfSense remain stable.
IP Address Conflicts	Medium	A strict IP Standard has been established. We will not change the lab IP range to avoid breaking Splunk forwarder configurations.
Log Injection Failure	High	Verify connectivity between Universal Forwarders and the Ubuntu Splunk instance (192.168.254.156) using ping and telnet on port 9997.
WAF False Positives	Medium	ModSecurity will be tested first in "Detection Only" mode on the WEBSRV before moving to "Enforcement" to avoid blocking legitimate HR/Finance traffic.

Key Performance Indicators (KPIs)

- **System Uptime:** 99% availability of the Splunk web interface during the 4-week testing phase.
- **Log Coverage:** 100% of critical endpoints (TEAM4-DC, WEBSRV, and pfSense) successfully forwarding logs to the indexer.
- **Detection Accuracy:** Zero "false negatives" during simulated SQL injection (targeting WEBSRV) and NTLM relay attacks.
- **Response Time:** Alert generation in Splunk within 2 minutes of a triggered security event, such as a Brute Force attempt.

2. Literature Review: Feedback & Evaluation

- **Lecturer's Assessment:** *[Pending final review of SOC Team4 implementation]*
- **Suggested Improvements:**

- Transition from local log storage on Windows to a dedicated Syslog-ng server for Linux logs to improve scalability.
 - Integrate an automated SOAR (Security Orchestration, Automation, and Response) platform to automatically block IPs in pfSense when Splunk triggers a High severity alert.
- **Final Grading Criteria:** 40% Technical Implementation (Splunk/pfSense config), 30% Testing (Attack simulations), 20% Documentation, 10% Presentation.

3. Requirements Gathering

Stakeholder Analysis

- **SOC Team (Users):** Need real-time visibility into network traffic and host logs to detect threats like Network Scanning.
- **Organization Management:** Require high-level KPI reports and evidence of incident containment.

User Stories & Use Cases

- **As a Threat Hunter,** I want to see a visualization of failed logins so I can identify Brute Force attacks early.
 - **As a Security Engineer,** I want to monitor the DMZ via pfSense/Suricata to ensure the Web Server (192.168.120.100) is protected from external SQLi attacks.
1. **Brute Force Attack Detection:** * **Description:** Adversaries attempt to gain access by guessing credentials through multiple login attempts (SSH, RDP, Web).
 - **Logic:** Identifying a high number of failed authentication attempts from a single source IP within a short time window.
 - **Impact:** Early detection allows the SOC to block offending IPs and reset credentials before ransomware deployment or account compromise occurs.
 2. **SQL Injection (SQLi) Monitoring:** * **Description:** Malicious SQL code is inserted into input fields or URLs to manipulate backend databases.
 - **Impact:** Critical for preventing data exfiltration of sensitive PII/financial data and full database compromise.
 3. **Network Scanning Reconnaissance:** * **Description:** Mapping live hosts, open ports, and services as part of the "Reconnaissance" phase of the Cyber Kill Chain.
 - **Impact:** Acts as a high-fidelity precursor to an attack; detecting it allows defenders to harden systems early.

4. System Analysis & Design

Problem Statement & Objectives

The project addresses the lack of visibility into unauthorized access and web-based attacks within a corporate network. The goal is to build a functional SOC environment using **Splunk**, **pfSense**, and **ModSecurity** to ingest and triage logs.

Software Architecture

The system follows a **Centralized SIEM Architecture**:

- **Endpoints:** Win 10 and Server 2019 using Universal Forwarders.
- **Network Tier:** pfSense acting as the security gateway with Suricata IDS.
- **Core Tier:** Ubuntu 22.04 LTS running Splunk Enterprise as the centralized data brain.

Functional Requirements

- **Authentication Monitoring:** The system must ingest Windows Event Log (EventCode 4625) and Linux /var/log/secure to identify failed logons.
- **Web Security:** Integration of Web Server access logs (Apache/XAMPP) and WAF logs (ModSecurity) to detect HTTP 401 status codes and SQL syntax like "UNION".
- **Network Intelligence:** Utilization of Firewall traffic logs and IDS/IPS logs (Suricata) to identify scanning patterns.

5. Implementation (Source Code & Execution)

Source Code & Scripts

- **SPL Rules:** Custom search queries for EventCode 4625 (Brute Force) and SQL Injection patterns.

SIEM Detection Rules (SPL)

The following rules are implemented within the Splunk environment to address the core use cases:

- **Brute Force Rule:**

Splunk SPL

```

index="windows_dc" EventCode=4625
| stats count min(_time) as firstTime max(_time) as lastTime by Source_Network_Address,
Account_Name
| where count >= 5
| eval severity="high"

```

- **SQL Injection Rule:**

Splunk SPL

```
index=* "UNION" | stats values(sourcetype) as "Source Types", count by host
```

- **Network Scanning Rule (Attacker IP 192.168.250.128):**

Splunk SPL

```

index="suricata" "192.168.250.128"
| rex "src_ip":\'(?:<src>[^\"]+)\''
| rex "dest_port":\'(?:<port>\d+)\''
| stats dc(port) as unique_ports_hit by src
| where unique_ports_hit > 10

```

README / Execution Guide

1. **Start Hypervisor:** Open VMware Workstation.
2. **Power On Sequence:** pfSense → Ubuntu (Splunk) → TEAM4-DC → Endpoints.
3. **Validation:** Access Splunk Web at <http://192.168.254.156:8000> and verify "Data Summary" shows logs from all hosts.

6. Testing & Quality Assurance

Test Plan & Scenarios

Based on the defined use cases, the following testing scenarios are conducted:

Test Cases

Test ID	Scenario	Expected Outcome
TC-01	Brute Force from Kali (192.168.250.128)	Splunk triggers alert after 5 failed attempts.
TC-02	SQL Injection on DVWA	ModSecurity logs the attempt; Splunk displays "UNION" query in dashboard.
TC-03	Nmap Scan via WAN	pfSense/Suricata logs traffic; alert generated in Splunk.

7. Final Presentation & Reports

- **Technical Documentation:** Included in this release, covering IP standards, AD credentials, and network segmentation.
- **Findings & Recommendations:** Based on simulations, the current i5-1235U setup handles the load well, but increasing the number of use cases beyond 10 may require upgrading to 32GB RAM.